ML-KEM-768 Adversarial Decapsulation Assessment

Negative decapsulation behavior of ML-KEM-768 (FIPS 203) across four implementations, measured with a runnable harness. Run: 2026-11-06T17:35:48Z–17:35:49Z (2026-11-07 00:35:48–00:35:49 WIB). Harness: `src/run_harness.py`. Full machine-readable results: `outputs/results.json` (2100 cases). Unedited log: `outputs/run_harness.log`. Digests: `outputs/SHA256SUMS`.

2100
cases run

300
MATCH

950
implicit rejections

400
errors (input checks)

400
not invoked (length guard)

50
not applicable

0
unexpected matches / mismatches / crashes

Implementations

ID	Implementation	Version	Key encoding
A	pyca/cryptography	50.0.2	ek 1184 B; dk as 64-byte seed (d‖z)
B	liboqs (ML-KEM-768, built from source)	0.12.0, commit f4b9622	ek 1184 B; sk 2400 B expanded
C	Go stdlib crypto/mlkem	go1.24.6	ek 1184 B; dk as 64-byte seed (d‖z)
D			

	pq-crystals/kyber Kyber768 reference (round-3, pre-FIPS 203 — lineage reference only)	commit 3edd5af	pk 1184 B; sk 2400 B

D implements round-3 Kyber768, not FIPS 203 ML-KEM: its shared secrets are not comparable with A/B/C. Only its behavioral class outcomes are compared.

Negative-test matrix

25 fresh keypairs per implementation. Outcome legend: **MATCH** — decapsulated secret equals the encapsulation secret. **IMPLICIT_REJECT** — a 32-byte secret different from the valid secret, no error (FIPS 203 §6.3, Algorithm 18). **ERROR** — the API raised an exception (type and message recorded verbatim in the log). **NOT_INVOKED** — the harness length guard refused to call a fixed-size C API with a wrong-length input (no C call was made). **NOT_APPLICABLE** — the key encoding has no stored region for that probe.

A — pyca/cryptography 50.0.2

Class	n	Outcome	Count
VALID	25	MATCH	25
MALFORMED-1BIT	75	IMPLICIT_REJECT	75
MALFORMED-MULTIBIT	25	IMPLICIT_REJECT	25
SYNTHETIC-CT	75	IMPLICIT_REJECT	75
WRONG-KEY	25	IMPLICIT_REJECT	25
CORRUPT-DK-D	25	IMPLICIT_REJECT	25
CORRUPT-DK-Z	25	MATCH	25
CORRUPT-DK-H	25	NOT_APPLICABLE	25
REPLAY-DETERMINISM	25	MATCH	25
WRONG-LENGTH-CT	175	ERROR:ValueError — “Invalid ML-KEM-768 ciphertext”	175

WRONG-LENGTH-DK	25	ERROR:ValueError — “An ML-KEM-768 seed is 64 bytes long” (at load)	25

B — liboqs 0.12.0

Class	n	Outcome	Count
VALID	25	MATCH	25
MALFORMED-1BIT	75	IMPLICIT_REJECT	75
MALFORMED-MULTIBIT	25	IMPLICIT_REJECT	25
SYNTHETIC-CT	75	IMPLICIT_REJECT	75
WRONG-KEY	25	IMPLICIT_REJECT	25
CORRUPT-DK-D	25	IMPLICIT_REJECT	25
CORRUPT-DK-Z	25	MATCH	25
CORRUPT-DK-H	25	IMPLICIT_REJECT	25
REPLAY-DETERMINISM	25	MATCH	25
WRONG-LENGTH-CT	175	NOT_INVOKED (fixed-size C API; wrapper enforces §7.3)	175
WRONG-LENGTH-DK	25	NOT_INVOKED (fixed-size C API; wrapper enforces §7.3)	25

C — Go 1.24.6 stdlib crypto/mlkem

Class	n	Outcome	Count
VALID	25	MATCH	25
MALFORMED-1BIT	75	IMPLICIT_REJECT	75
MALFORMED-MULTIBIT	25	IMPLICIT_REJECT	25
SYNTHETIC-CT	75	IMPLICIT_REJECT	75
WRONG-KEY	25	IMPLICIT_REJECT	25

CORRUPT-DK-D	25	IMPLICIT_REJECT	25
CORRUPT-DK-Z	25	MATCH	25
CORRUPT-DK-H	25	NOT_APPLICABLE	25
REPLAY-DETERMINISM	25	MATCH	25
WRONG-LENGTH-CT	175	ERROR:RuntimeError — “mlkem: invalid ciphertext length” (174 cases; the 0-byte case is rejected by the Go driver’s argument check)	175
WRONG-LENGTH-DK	25	ERROR:RuntimeError — “mlkem: invalid seed length” (at load)	25

D — pq-crystals/kyber Kyber768 reference

Class	n	Outcome	Count
VALID	25	MATCH	25
MALFORMED-1BIT	75	IMPLICIT_REJECT	75
MALFORMED-MULTIBIT	25	IMPLICIT_REJECT	25
SYNTHETIC-CT	75	IMPLICIT_REJECT	75
WRONG-KEY	25	IMPLICIT_REJECT	25
CORRUPT-DK-D	25	IMPLICIT_REJECT	25
CORRUPT-DK-Z	25	MATCH	25
CORRUPT-DK-H	25	IMPLICIT_REJECT	25
REPLAY-DETERMINISM	25	MATCH	25
WRONG-LENGTH-CT	175	NOT_INVOKED (fixed-size C API; wrapper enforces §7.3)	175
WRONG-LENGTH-DK	25	NOT_INVOKED (fixed-size C API; wrapper enforces §7.3)	25

Cross-implementation agreement (FIPS 203 ML-KEM-768 only)

- **Leg 1 (A ↔ C):** same 64-byte seed `000102…3e3f` loaded into pyca (`from_seed_bytes`) and Go (`NewDecapsulationKey768`); encapsulation by Go with pyca's ek. Go encap ss, pyca decap ss, Go decap ss all identical (`c55d3f85cf91d9b105c1fe0fd26cafc8ee31a074fbfd93454d5aac891db42947`). **Agree: yes.**
- **Leg 2 (B ↔ A):** keypair generated by liboqs; encapsulation by pyca with liboqs's ek (`from_public_bytes`); decapsulation by liboqs. pyca encap ss == liboqs decap ss (`bfa2c9673d165c1cf58aa15e19fb281212029c1002e6e441c9c1047ec41b02e9`). **Agree: yes.**
- **All three FIPS 203 implementations agree** (by transitivity of the two legs).

Findings

F-1 — Low: liboqs 0.12.0 and the Kyber reference do not enforce the FIPS 203 §7.3 decapsulation-key hash check

Corrupting one byte inside the stored `H(ekPKE)` region of the expanded decapsulation key (byte 2350 of 2400) and decapsulating a valid ciphertext yields a wrong 32-byte shared secret in 25/25 cases for liboqs and 25/25 for the Kyber reference — no error is raised. §7.3 requires the hash check `H(dk[1152:2336]) == dk[2336:2368]` before `ML-KEM.Decaps` runs. §7.3 permits the key check to be performed by means other than the decapsulating party, so this is a validation gap, not a standard violation. Callers must perform the §7.3 hash check themselves before handing a decapsulation key to liboqs. The Kyber reference predates FIPS 203, so the §7.3 framing applies to liboqs. pyca and Go store the key as the 64-byte seed, so the probe does not apply to them.

F-2 — Informational: fixed-size C APIs cannot enforce the §7.3 length checks; the caller must

liboqs (`OQS_KEM_decaps`) and the Kyber reference (`crypto_kem_dec`) take fixed-size buffers and assume a 1088-byte ciphertext and a 2400-byte decapsulation key. The harness wrapper enforces the §7.3 length checks before every call (400 cases `NOT_INVOKED`, zero C calls with a wrong-length buffer). pyca and Go enforce the checks inside the API (wrong-length ciphertext → error; wrong-length key rejected at load).

F-3 — Positive: implicit rejection is uniformly correct across all four implementations

950/950 adversarial-input cases returned a 32-byte rejection secret different from the valid secret, with no error and no crash — exactly FIPS 203 §6.3 Algorithm 18. Corrupting the z-region leaves valid-ciphertext decapsulation unchanged (25/25 MATCH per implementation), because z is only consumed on the rejection path (`J(z‖c)`, step 7).

F-4 — Positive: the three FIPS 203 implementations agree on shared secrets

Cross-implementation agreement holds in both legs (see above). No distinguishable failure, non-rejection secret, or crash was found in any of the 2100 cases.

Claim-to-evidence index (summary)

Claim	Statement	Evidence
M-1	Valid ciphertext → valid shared secret (25/25 each)	results.json, class VALID
M-2	Single-bit ciphertext flip → implicit rejection (75/75 each)	results.json, MALFORMED-1BIT
M-3	Zeroed 32-byte ciphertext block → implicit rejection (25/25 each)	results.json, MALFORMED-MULTIBIT

M-4	Synthetic ciphertexts (zero / 0xFF / random) → implicit rejection (75/75 each)	results.json, SYNTHETIC-CT
M-5	Wrong-key decapsulation → implicit rejection (25/25 each)	results.json, WRONG-KEY
M-6	Corrupted d-region of key → implicit rejection (25/25 each)	results.json, CORRUPT-DK-D
M-7	Corrupted z-region → valid ciphertext still decapsulates (25/25 MATCH each)	results.json, CORRUPT-DK-Z
M-8	pyca and Go enforce the §7.3 ciphertext length check (175/175 each)	results.json, WRONG-LENGTH-CT
M-9	pyca and Go reject a wrong-length key at load (25/25 each)	results.json, WRONG-LENGTH-DK
M-10	liboqs and Kyber reference do not enforce the §7.3 key hash check (25/25 each)	results.json, CORRUPT-DK-H; F-1
M-11	Fixed-size C APIs cannot take wrong-length inputs; wrapper enforces the checks (400 NOT_INVOKED)	results.json, WRONG-LENGTH-CT/DK; F-2
M-12	Three FIPS 203 implementations agree on shared secrets (both legs)	results.json, cross_implementation
M-13	No crash, unexpected match, or non-32-byte output in 2100 cases	results.json outcome distribution; run_harness.log

Sources and reproduction

- FIPS 203 (NIST.FIPS.203, Aug 2024) — `outputs/raw/fips-203.pdf` (SHA-256 `fe1f12f32a7e44ec9fdebbf400cda843a40b506dee676725234dc6f7923b6cac`)
- liboqs 0.12.0 — commit `f4b96220e4bd208895172acc4fedb5a191d9f5b1`
- pq-crystals/kyber — commit `3edd5af5991927164edd4aacebfcbee00b8064e7`
- pyca/cryptography 50.0.2; Go 1.24.6 stdlib `crypto/mlkem`
- Repository: github.com/araupooo/mlkem-768-adversarial-decapsulation

- Key files (direct fetch): matrix.md · findings.md · outputs/results.json

Reproduce: `python3 -m venv /tmp/mlkem-prep-venv && /tmp/mlkem-prep-venv/bin/pip install "cryptography==50.0.2"`, build liboqs 0.12.0, the Go driver (go1.24.6) and the Kyber driver (gcc) as in `README.md`, then `/tmp/mlkem-prep-venv/bin/python src/run_harness.py > outputs/run_harness.log`. Expected: exit 0, `TOTAL CASES: 2100`, `CROSS-IMPL ALL THREE AGREE (by transitivity): True`.